

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Supply Chain Management and ISO/IEC 27036

1. Learning Objectives

By the end of this lecture, you will be able to:

- Explain why supply chain risk in cloud environments extends beyond the direct provider relationship to encompass sub-vendors and sub-processors.
- Describe the structure and purpose of each part of ISO/IEC 27036, the international standard for supplier relationship security.
- Explain how the SolarWinds incident reshaped organisational approaches to software supply chain risk.
- Apply supply chain security requirements from GDPR Article 28 and the Sarbanes-Oxley Act to cloud vendor scenarios.
- Identify common exam traps related to supply chain risk scope and the use of frameworks like ISO/IEC 27036.

2. Introduction: Trust Is Multilateral, Not Bilateral

A global pharmaceutical company had invested three years building a cloud security programme. Its primary cloud provider was assessed annually, maintained current certifications, and had never experienced a notifiable breach. The company's security leadership considered the provider relationship one of their strongest controls. Then a firmware update distributed through a hardware vendor in the provider's supply chain introduced a persistent implant that went undetected for eleven months. The entry point was not the primary provider. It was a third-tier supplier that no one in the pharmaceutical company had ever heard of.

This is the defining challenge of supply chain management in cloud environments: the perimeter of your security is not where your contracts end. It extends to every vendor your provider depends on, every vendor those vendors depend on, and every software update distributed through any link in that chain. The attacker does not need to defeat your controls. They need to find the weakest link that has access to something you trust — and that link may be entirely outside your line of sight.

ISO/IEC 27036 was developed precisely to give organisations a structured framework for managing this layered risk. Understanding its structure, combined with the supply chain transparency obligations imposed by GDPR and the Sarbanes-Oxley Act, is what CCSP candidates need to apply in scenario-based exam questions where the attack vector is not the direct provider but something further back in the chain.

3. Core Concepts Explained

3a. Why Supply Chain Risk Is Distinctive in Cloud Environments

Definition: Supply chain risk in information and communication technology refers to the risk that hardware, software, or service components sourced from external providers introduce vulnerabilities — deliberately or accidentally — that affect the security of systems that depend on them.

Business relevance: In a traditional on-premises environment, the supply chain is primarily hardware and software vendors. In a cloud environment, the supply chain expands dramatically. The cloud provider itself depends on hardware manufacturers, operating system vendors, virtualisation software suppliers, managed security service providers, content delivery networks, and dozens of specialised sub-processors. Each of those relationships is a node in the supply chain, and a compromise at any node can propagate to every customer who depends on the affected component.

Practitioner angle: The distinction between supply chain risk and direct vendor risk is important for both security programme design and regulatory compliance. Organisations that assess only their direct cloud provider satisfy the minimum contractual due diligence but leave significant exposure. A mature programme maps the sub-vendor relationships at least two tiers deep and builds verification requirements into procurement contracts so that security obligations flow through the chain rather than terminating at the first tier.

Real-world example: The SolarWinds incident, discovered in December 2020, demonstrated that a trusted software update from an established vendor could serve as a vehicle for distributing malware to approximately eighteen thousand organisations simultaneously — including government agencies and critical infrastructure operators. The attackers did not breach customer networks directly. They compromised SolarWinds' own build environment, inserting malicious code into a routine software update that was then distributed through the trusted update mechanism that customers had every reason to apply.

Risks if supply chain is not managed: Undetected compromise of sub-vendor infrastructure; propagation of malware through trusted update mechanisms; inability to demonstrate regulatory compliance (SOX, GDPR) for controls operated at sub-provider tiers; lack of contractual recourse because obligations were not flowed down through the supply chain.

3b. ISO/IEC 27036: Structure and Purpose

ISO/IEC 27036 is the international standard specifically developed for information security in supplier relationships. It is a four-part standard, and the CCSP exam expects familiarity with each part's scope.

Part 1 — Overview and Concepts: Establishes the foundational vocabulary and scope for the entire standard. Defines what constitutes a supplier relationship, distinguishes between acquirers (organisations that use goods or services) and suppliers (organisations that

provide them), and categorises the types of risk associated with supplier relationships. This part provides the common language that Parts 2, 3, and 4 build on.

Part 2 — Requirements: Contains the actual controls and processes that organisations — both acquirers and suppliers — must implement to establish and maintain secure supplier relationships. Requirements include risk assessment processes for evaluating whether a particular supplier relationship introduces unacceptable risk, contractual security obligations that must be established in writing before a supplier engagement begins, and monitoring processes to verify that suppliers continue to meet security commitments throughout the relationship lifecycle, not just at initial assessment.

Part 3 — Guidelines for ICT Supply Chain Security: Addresses the particular challenges of hardware integrity (confirming that physical components have not been tampered with in manufacturing or distribution), software assurance (verifying that software delivered by a supplier has not been altered from the authorised release), and management of sub-suppliers (building security requirements into tier-two and tier-three vendor relationships). This part provides detailed guidance for procurement processes so that security criteria are evaluated before a contract is signed.

Part 4 — Guidelines for Cloud Service Security: Applies the broader framework specifically to cloud service relationships, which present unique challenges because of the multi-layered sub-processor model. A single cloud service may depend on dozens of sub-processors for functions including logging, backup, content delivery, and identity management. Part 4 addresses how to evaluate cloud providers, how to manage the sub-processor chain, and how to ensure that security requirements flow through each tier of the cloud service arrangement.

3c. Regulatory Supply Chain Transparency Requirements

Supply chain security is not only a best-practice framework area — it is a regulatory obligation under two major frameworks that the CCSP exam addresses.

Sarbanes-Oxley Act (SOX): SOX applies to publicly listed companies in the United States and requires that organisations maintain accurate, verified records of IT controls that affect financial reporting — including controls operated by third-party service providers. If a cloud provider processes financial data on behalf of the customer, the provider's IT controls fall within the scope of SOX compliance. The organisation cannot simply assert that it has outsourced the function. It must demonstrate that the controls are effective, which typically requires SOC 1 reports from the cloud provider. SOX compliance therefore creates a direct obligation to manage and verify the supply chain for financial systems, regardless of whether the organisation believes it has complete control over those systems.

General Data Protection Regulation (GDPR): GDPR Article 28 requires that data controllers know where personal data is processed and by whom throughout the full processing chain. When a cloud provider engages sub-processors to handle data on behalf of a customer, the controller must be informed of those arrangements in advance and must retain the right to object to new sub-processors being added. Sub-processor contracts must impose data

protection obligations on the sub-processor that are at least equivalent to those imposed on the primary processor by the data processing agreement. This means the chain of accountability must be traceable through every tier. An organisation cannot satisfy GDPR obligations by managing its direct provider relationship and ignoring the sub-processor chain.

4. ISO/IEC 27036: Four-Part Structure at a Glance

Part	Title	Primary Focus	CCSP Exam Relevance
Part 1	Overview and Concepts	Definitions, scope, acquirer-supplier relationship vocabulary	Provides vocabulary for other parts; tested in context questions
Part 2	Requirements	Controls and processes for secure supplier relationships; ongoing monitoring	Most directly tested — know what 'requirements' cover vs. guidelines
Part 3	ICT Supply Chain Guidelines	Hardware integrity, software assurance, sub-supplier management, procurement security	SolarWinds-type scenarios; software assurance requirements
Part 4	Cloud Service Guidelines	Cloud-specific sub-processor chains, cloud provider evaluation, security flow-down	Directly tested for cloud-context supply chain questions

5. SOX vs. GDPR Supply Chain Requirements

Dimension	Sarbanes-Oxley (SOX)	GDPR Article 28
Jurisdiction	United States (publicly listed companies)	European Union (any organisation handling EU personal data)
Trigger	Cloud provider handles systems affecting financial reporting	Cloud provider processes personal data as a processor
Obligation	Demonstrate effectiveness of provider IT controls over financial data	Know all sub-processors; right to object to new ones; flow-down obligations
Evidence required	SOC 1 Type II report from provider	Data processing agreement with sub-processor notification and objection rights
Chain depth	Primarily direct provider, with evidence of their	All sub-processors at every tier touching personal data

	control effectiveness	
Penalty for non-compliance	Criminal and civil liability for executives; restatement risk	Fines up to 4% of global annual turnover; enforcement by data protection authority

6. Case Study: SolarWinds and the Trusted Update Vector

Incident: In December 2020, cybersecurity firm FireEye (now Mandiant) discovered that attackers had compromised the build environment of SolarWinds, a company providing IT management software widely used by government agencies, defence contractors, and major corporations. The attackers inserted malicious code — named SUNBURST — into a routine software update for SolarWinds' Orion platform. Because the update was digitally signed by SolarWinds and distributed through the company's legitimate update mechanism, it bypassed security controls at approximately eighteen thousand customer organisations. The attacker then activated a subset of these implants for follow-on intrusion into high-value targets including multiple US federal agencies. The incident is significant for supply chain security in several ways: the entry point was not the customer's infrastructure but a trusted supplier's internal systems; the attack used a mechanism (software updates) that customers had positive incentives to apply promptly; and detection relied on anomalous network behaviour noticed by a security company conducting its own internal investigation, not by the affected agencies' monitoring systems.

The SolarWinds incident prompted a reassessment of software supply chain risk across both government and commercial sectors. In the United States, an executive order on improving cybersecurity required new standards for software supply chain security for federal agencies, including requirements for software bills of materials (SBOMs) that identify all components in a software product. Organisations applying ISO/IEC 27036 Part 3 principles now give explicit attention to software assurance requirements when evaluating vendors, including whether the vendor can provide evidence of secure development practices and integrity verification for distributed updates.

7. Memory Anchor

Think of it this way: Supply chain security is like a restaurant kitchen's food safety programme. The chef controls what happens in the kitchen, but the food arrives from suppliers who sourced ingredients from farmers who may have used sub-suppliers for seed or equipment. Food safety regulations impose traceability requirements that go back to the origin of every ingredient — not because the chef is negligent, but because an undetected problem at any upstream point produces a result the chef cannot fix at the cooking stage. ISO/IEC 27036 is the traceability standard for information security supply chains. It does not assume your direct provider is negligent — it assumes that

complex supply chains have complex risk, and that you need a framework for managing it all the way down.

8. Exam Focus

High-priority exam topics in this area:

- ISO/IEC 27036 part numbers and their scope — expect questions asking which part addresses cloud services (Part 4), hardware integrity (Part 3), or contractual requirements (Part 2). Know the parts well enough to place them given a scenario description.
- Supply chain risk scope — the exam will describe a scenario where a breach originates with a sub-vendor rather than the direct provider. The correct answer identifies that supply chain risk does not stop at the first tier and that ISO/IEC 27036 provides the framework for extending oversight.
- GDPR sub-processor obligations — know that GDPR Article 28 requires controllers to be notified of sub-processors, retain objection rights, and ensure flow-down of data protection obligations. The exam distinguishes this from the general data processing agreement requirements.
- SOX and SOC 1 — SOX requires evidence of IT controls affecting financial reporting. The appropriate evidence is a SOC 1 report. Avoid the distractor that SOC 2 satisfies SOX requirements.
- SolarWinds as an exam scenario template — the exam may describe a scenario involving malicious code distributed through a trusted software update without naming SolarWinds. Recognise this as a software supply chain attack and apply Part 3 or Part 4 of ISO/IEC 27036.
- Common exam trap: assuming supply chain management ends with the direct cloud provider. In exam scenarios, the correct answer almost always acknowledges that risk flows through sub-vendor relationships and that the organisation must build visibility and contractual obligations down through the chain.

9. Key Terms Glossary

Supply chain risk: The risk that hardware, software, or services sourced from external vendors introduce vulnerabilities that propagate to systems depending on those components.

ISO/IEC 27036: The international multi-part standard for information security in supplier relationships, covering overview and concepts, requirements, ICT supply chain guidelines, and cloud service guidelines.

Acquirer: In ISO/IEC 27036, the organisation obtaining goods or services from a supplier; typically the cloud customer in a cloud service context.

Supplier: In ISO/IEC 27036, the organisation providing goods or services; typically the cloud provider or sub-processor.

Software assurance: Processes and requirements verifying that software delivered by a supplier has not been altered from the authorised release and does not contain unintended functionality.

Sub-processor: A third party engaged by the primary cloud provider to perform data processing functions as part of the service delivery chain, with GDPR-specific notification and flow-down obligations.

GDPR Article 28: The GDPR provision governing data processor obligations, including requirements for data processing agreements, sub-processor notification, and flow-down of data protection obligations.

Sarbanes-Oxley Act (SOX): US legislation requiring publicly listed companies to maintain verifiable IT controls over financial reporting, including controls operated by third-party cloud providers.

SOC 1 report: An audit report assessing service organisation controls relevant to user organisations' internal control over financial reporting; the primary SOX-relevant report type for cloud providers.

Software Bill of Materials (SBOM): A formal record identifying all components (libraries, frameworks, and dependencies) in a software product, used to support supply chain transparency and vulnerability tracking.

SUNBURST: The name given to the malicious backdoor inserted into the SolarWinds Orion platform update during the 2020 supply chain attack.

Security flow-down: The contractual mechanism requiring that a direct supplier pass security obligations to its own sub-suppliers, ensuring consistent standards throughout the supply chain.

10. Quick Revision Checklist

- ☐ I can explain why supply chain risk in cloud environments extends beyond direct provider relationships to sub-vendors and sub-processors.
- ☐ I know the four parts of ISO/IEC 27036 and can describe the primary focus of each.
- ☐ I can explain what the SolarWinds incident demonstrated about the software supply chain attack vector.
- ☐ I understand what GDPR Article 28 requires regarding sub-processor notification, objection rights, and obligation flow-down.
- ☐ I know why SOX compliance requires SOC 1 reports (not SOC 2) for cloud providers handling financial data.
- ☐ I can distinguish between supply chain risk management at the first tier versus a mature multi-tier programme.
- ☐ I understand the difference between ISO/IEC 27036 Part 3 (ICT supply chain) and Part 4 (cloud service guidelines).

- ☐ I can apply the restaurant kitchen analogy to explain why upstream supply chain problems cannot be fixed at the point of delivery.
- ☐ I know that security flow-down is the contractual mechanism for extending obligations through sub-vendor tiers.
- ☐ I can identify exam scenarios where a breach originates with a sub-vendor and select answers that apply ISO/IEC 27036 appropriately.

11. Practice Questions

Question 1 (Scenario-Based)

Scenario: A publicly listed US-based company uses a cloud provider to host its financial consolidation and reporting system. An external auditor reviewing the company's SOX compliance programme requests evidence that the controls operated by the cloud provider are effective. The company provides its cloud provider's SOC 2 Type II report. The auditor advises that this is not sufficient for SOX purposes and requests a different document. What should the company provide, and why?

A. The ISO/IEC 27001 certificate, because it demonstrates that the provider maintains a certified information security management system.

→ Incorrect. ISO/IEC 27001 certifies the provider's information security management system against a broad control framework. It is not designed to assess controls specifically relevant to financial reporting. SOX requires targeted evidence of financial reporting controls, which ISO/IEC 27001 does not provide.

B. The SOC 1 Type II report, because it assesses controls relevant to the user organisation's internal control over financial reporting.

→ Correct. SOC 1 (issued under SSAE 18 in the US, or ISAE 3402 internationally) is specifically designed to assess service organisation controls that affect a user organisation's financial reporting. SOX compliance for systems operated by a cloud provider requires a SOC 1 report demonstrating design and operating effectiveness of those controls. SOC 2 addresses the Trust Services Criteria (security, availability, processing integrity, confidentiality, privacy) — useful for general security assurance but not the SOX-specific evidence the auditor needs.

C. The SOC 3 report, because it is publicly available and demonstrates that the provider met all required control criteria.

→ Incorrect. SOC 3 is a summary version of SOC 2 findings designed for general public distribution. It contains less detail than SOC 2 and covers the same Trust Services Criteria scope. It does not address financial reporting controls and is not sufficient for SOX compliance.

D. The provider's penetration test results, because they demonstrate active control verification rather than certification-based assurance.

→ Incorrect. Penetration test results demonstrate the effectiveness of specific technical controls against exploitation at a point in time. They are not an assessment of internal controls over financial reporting and do not satisfy the structural requirements of SOX compliance evidence.

Question 2 (Scenario-Based)

Scenario: A data controller based in Germany discovers that its cloud provider recently began using a sub-processor based in Vietnam to perform data compression services on personal data files. The controller was not informed in advance. The controller's data protection officer asks which specific GDPR provision this violates and what action the controller should take. What is the correct analysis?

A. GDPR Article 17 (right to erasure) was violated because the sub-processor may have retained copies of personal data beyond the authorised period.

→ Incorrect. Article 17 governs data subjects' rights to request deletion of their personal data. The issue here is not retention period but the failure to notify the controller of a new sub-processor arrangement, which is governed by Article 28.

B. GDPR Article 28 was violated because the processor engaged a new sub-processor without obtaining the controller's prior consent or providing the opportunity to object, and the controller should formally object, seek an explanation of the sub-processor engagement, and assess whether continued processing by the sub-processor can be authorised.

→ Correct. Article 28(2) requires that where a processor uses a sub-processor, it must obtain the controller's prior specific or general authorisation and must inform the controller of intended changes to sub-processors, giving the controller the opportunity to object. The controller's response should be to formally assert its objection rights under the data processing agreement, require the provider to suspend or regularise the sub-processor arrangement, and document its response for regulatory purposes.

C. The General Data Protection Regulation does not apply because the sub-processor is located outside the European Union.

→ Incorrect. GDPR applies to the processing of personal data of individuals in the EU regardless of where the processing organisation is located. The controller's data processing obligations, including Article 28 requirements, apply to the entire processing chain, including sub-processors outside the EU — who must also meet the standard protection requirements or benefit from an appropriate transfer mechanism.

D. GDPR Article 25 (data protection by design and by default) was violated because the sub-processor's compression service may not have applied appropriate technical safeguards.

→ Incorrect. While Article 25 may also be relevant if the compression process introduces technical risks, the primary violation described in this scenario is the failure to notify the controller of the new sub-processor arrangement, which is Article 28. The question asks for the specific provision violated by the notification failure.

Question 3 (Scenario-Based)

Scenario: An organisation's security team is investigating why a cloud-hosted enterprise resource planning system began sending anomalous data to an external IP address. Investigation reveals that a logging module within the ERP platform was updated three months ago by the ERP vendor, and that the update contained code introduced at the vendor's build server by an attacker who had gained persistent access six months earlier. No authentication breach occurred at the customer or cloud provider. Which part of ISO/IEC 27036 most directly addresses the security requirements that should have prevented this incident?

A. Part 1, because it defines the vocabulary for describing this type of supplier relationship.

→ Incorrect. Part 1 provides foundational vocabulary and concepts. It does not contain requirements or controls applicable to preventing supply chain compromises. Understanding the terms is necessary but insufficient.

B. Part 2, because it contains the contractual requirements that should have obligated the vendor to maintain secure development practices and notify the customer of anomalous build environment activity.

→ Partially correct but not the most specific answer. Part 2 addresses requirements for the supplier relationship generally, including contractual obligations. However, the specific mechanism of compromise — insertion into a software update's build process — is most directly addressed in Part 3.

C. Part 3, because it provides guidelines for ICT supply chain security including software assurance requirements that address the integrity of software distributed through vendor update mechanisms.

→ Correct. Part 3 specifically addresses ICT supply chain security challenges including software assurance — the processes and technical requirements for verifying that software delivered through vendor channels has not been altered from the authorised release. Build environment security and update integrity verification are Part 3 concerns. The incident described mirrors the SolarWinds attack pattern, which is the defining example of the risk that Part 3 was developed to address.

D. Part 4, because the ERP platform was hosted in a cloud environment and cloud-specific guidelines apply.

→ Incorrect. Part 4 addresses cloud service security guidelines, primarily for the relationship between cloud service customers and cloud providers and the management of cloud sub-processors. The compromise described occurred in the ERP vendor's internal build environment, which is an ICT supply chain issue addressed in Part 3, not a cloud-provider-specific issue.

Question 4

Which statement best characterises the difference between ISO/IEC 27036 Part 2 and Part 3?

A. Part 2 contains guidelines; Part 3 contains mandatory requirements.

→ Incorrect. This is the reverse of the actual structure. Part 2 contains requirements (mandatory controls and processes). Part 3 provides guidelines (detailed guidance without prescribing mandatory implementation methods). The distinction between 'requirements' and 'guidelines' in ISO/IEC standards is significant.

B. Part 2 contains the mandatory requirements for secure supplier relationships including contractual obligations and monitoring; Part 3 provides detailed guidelines for managing ICT supply chain risks including hardware integrity and software assurance.

→ Correct. Part 2 is the requirements part — it specifies what organisations must do. Part 3 is the guidelines part for ICT supply chains specifically — it explains how to implement practices such as hardware integrity verification, software assurance, and sub-supplier management.

C. Part 2 applies only to software vendors; Part 3 applies only to hardware vendors.

→ Incorrect. ISO/IEC 27036 Parts 2 and 3 both apply across the range of ICT supplier relationships. The parts are not divided by supplier type (hardware vs. software) but by the nature of the content (requirements vs. implementation guidelines for ICT supply chain security).

D. Part 2 is the cloud-specific part; Part 3 is the hardware-specific part.

→ Incorrect. Part 4 is the cloud-specific guidelines part. Part 3 addresses ICT supply chain security broadly, including hardware integrity and software assurance. Confusing the part numbers is a common source of exam errors.

Question 5

An organisation wants to ensure that its cloud provider cannot engage new sub-processors without prior notification. Which contractual and regulatory mechanism should it rely on?

A. Include a right-to-audit clause that permits the organisation to review sub-processor contracts annually.

→ Incorrect. A right-to-audit clause gives the customer access to review provider controls or documentation. It does not prevent the provider from engaging new sub-processors without prior notice; it only gives the customer the right to discover that a change occurred after it has already happened.

B. Require the provider to maintain ISO/IEC 27036 Part 4 certification, which prohibits sub-processor additions without customer consent.

→ Incorrect. ISO/IEC 27036 is a standards framework, not a certification scheme that prohibits specific operational actions. Compliance with the framework does not create an automatic prohibition on sub-processor additions; the contractual obligation must be established in the data processing agreement.

C. Establish a data processing agreement incorporating GDPR Article 28 requirements, including prior notification of sub-processor changes and the controller's right to object.

→ Correct. GDPR Article 28(2) and the data processing agreement are the mechanism for ensuring controllers are informed of new sub-processors before the engagement begins and retain the right to object. The contractual provision operationalises the regulatory obligation. Without this specific provision in the agreement, the customer has no advance notification right regardless of the provider's general certifications.

D. Request that the provider include sub-processor information in its annual SOC 2 Type II report.

→ Incorrect. A SOC 2 report may disclose sub-processors as part of the system description, but it is a retrospective assessment, not a real-time notification mechanism. It does not provide advance notification of intended changes or give the controller the right to object before a new sub-processor is engaged.

Question 6

What was the primary attack vector used in the SolarWinds SUNBURST campaign, and what principle of supply chain security does it most directly violate?

A. Phishing emails targeting SolarWinds customers; this violates the principle of user authentication for cloud access.

→ Incorrect. The SolarWinds attack did not use phishing against customers. The attacker compromised SolarWinds' own internal build environment, inserting malicious code into software updates before they were distributed. Authentication of cloud access is not the relevant principle.

B. A compromised software update distributed through SolarWinds' legitimate update mechanism; this violates software assurance principles requiring integrity verification of software distributed through vendor channels.

→ Correct. SUNBURST was distributed as a malicious component embedded in a signed, legitimate-appearing software update. The update passed routine verification checks because it was genuinely signed by SolarWinds. Software assurance principles — as addressed in ISO/IEC 27036 Part 3 — require that organisations implement mechanisms to verify the integrity and authenticity of software delivered by vendors at the build process level, not only at the distribution level.

C. Exploitation of a zero-day vulnerability in SolarWinds' customer-facing API; this violates the principle of secure software development lifecycle for cloud platforms.

→ Incorrect. The SUNBURST attack did not exploit a zero-day vulnerability in a customer-facing API. It used a compromised build environment to insert malicious code into a software update. The attack was in the vendor's internal supply chain, not in a customer-facing API surface.

D. Unauthorised access to SolarWinds customer cloud environments using stolen credentials; this violates the principle of privileged access management for cloud systems.

→ Incorrect. The initial entry point was not stolen credentials for customer environments. The attackers compromised SolarWinds' build server and inserted backdoor code into the Orion product. Subsequent exploitation of high-value targets occurred after the backdoor was activated, but the supply chain attack vector was the defining characteristic of the campaign.

Question 7

Under GDPR Article 28, when a cloud provider engages a sub-processor, which obligation must be imposed on the sub-processor through contract?

A. The sub-processor must obtain separate consent from each data subject whose data it processes.

→ Incorrect. Consent from data subjects is a lawful basis for processing, managed at the controller level. Sub-processor contracts do not require separate data subject consent; they require that the sub-processor is bound by data protection obligations equivalent to those in the controller-processor contract.

B. The sub-processor must achieve ISO/IEC 27001 certification before being permitted to process personal data.

→ Incorrect. GDPR does not require ISO/IEC 27001 certification as a prerequisite for sub-processor engagement. The obligation is contractual: the sub-processor must be bound by data protection obligations at least equivalent to those imposed on the primary processor.

C. Data protection obligations at least equivalent to those in the data processing agreement between the controller and the primary processor must be imposed on the sub-processor by contract.

→ Correct. GDPR Article 28(4) requires that where a processor engages a sub-processor, it must impose equivalent data protection obligations on that sub-processor through a contract. This is the 'flow-down' principle: the controller's data protection requirements must be traceable all the way down to every party that handles the personal data, not just to the first tier.

D. The sub-processor must register as a data processor with the relevant data protection authority in its home jurisdiction.

→ Incorrect. GDPR does not require processors or sub-processors to register with data protection authorities as a condition of processing personal data. Notification and registration obligations vary by member state and apply in specific circumstances, but registration of sub-processors is not the mechanism GDPR Article 28 uses to address sub-processor obligations.

Question 8

Which statement most accurately describes the scope of an organisation's supply chain security obligations under a mature supply chain management programme aligned with ISO/IEC 27036?

A. The obligation covers the direct cloud provider only, because the organisation has no contractual relationship with sub-vendors.

→ Incorrect. This reflects the most common misconception about supply chain security scope. A mature programme aligned with ISO/IEC 27036 recognises that risk flows through sub-vendor relationships regardless of whether the customer has a direct contractual relationship with each sub-vendor. The requirement is to build visibility into the chain and impose flow-down obligations contractually through the direct provider.

B. The obligation covers the direct cloud provider and all sub-vendors at every tier that could affect the security of the organisation's data or systems, with security requirements flowed down contractually through the supply chain.

→ Correct. ISO/IEC 27036 takes a comprehensive view of the supply chain: risk does not terminate at the first tier, and organisations must build mechanisms for visibility and accountability throughout the chain. In practice, this means building sub-vendor security requirements into the primary contract and verifying that those requirements flow through subsequent tiers, even where the customer has no direct relationship with those sub-vendors.

C. The obligation covers the direct cloud provider and one tier of sub-vendors, with no requirements beyond that because of diminishing risk at deeper tiers.

→ Incorrect. There is no one-tier limitation in ISO/IEC 27036 or in GDPR supply chain obligations. The SolarWinds incident demonstrated that sophisticated attackers specifically target less-scrutinised tiers in the supply chain. Stopping at one tier below the direct provider leaves a significant gap.

D. The obligation covers only sub-vendors that are identified in the cloud provider's SOC 2 report system description.

→ Incorrect. A SOC 2 system description may or may not enumerate all sub-vendors, and its scope is determined by the assessment framework, not by the customer's risk exposure. Limiting supply chain oversight to what appears in a third-party report delegates risk scoping to the provider being assessed.

Question 9

ISO/IEC 27036 Part 4 specifically addresses which supply chain challenge that is less prominent in other parts of the standard?

A. Hardware component tampering during manufacturing and shipping.

→ Incorrect. Hardware tampering during manufacturing and distribution is addressed in Part 3 (ICT supply chain guidelines). Part 4 addresses the specific characteristics of cloud service relationships, not manufacturing-phase hardware integrity.

B. The management of multi-layered sub-processor relationships in cloud service arrangements, where a single cloud service may depend on dozens of sub-processors for specialised functions.

→ Correct. Part 4 applies the supply chain security framework to the characteristics of cloud services, where the sub-processor model is more complex and layered than in traditional ICT supplier relationships. A single cloud platform may depend on multiple sub-processors for logging, backup, content delivery, identity management, and other functions, each of which represents a link in the security chain. Part 4 provides guidance on evaluating cloud providers and ensuring that security obligations flow through this layered structure.

C. Contractual requirements for supplier relationships, including monitoring obligations throughout the contract lifecycle.

→ Incorrect. Contractual requirements and lifecycle monitoring are addressed in Part 2. Part 4 is a guidelines part specifically focused on cloud service security characteristics.

D. Vocabulary and definitions for the acquirer-supplier relationship applicable across all supplier types.

→ Incorrect. Vocabulary and foundational definitions are established in Part 1. Part 4 applies the framework to the cloud-specific context; it builds on the vocabulary established in Part 1 rather than establishing it.

Question 10

A CCSP exam question describes an organisation that assessed its cloud provider's security comprehensively and obtained current certifications, but then suffered a breach originating from a third-tier vendor that provided firmware to the cloud provider's hardware manufacturer. Which principle does the correct answer to this scenario most likely reflect?

A. The organisation should have assessed the cloud provider's penetration test results, which would have detected firmware vulnerabilities.

→ Incorrect. Penetration testing assesses exploitable vulnerabilities in systems under test, not the integrity of firmware from third-tier vendors. A penetration test would not typically discover a supply chain compromise originating in a firmware vendor's manufacturing process.

B. The organisation's failure to extend supply chain oversight beyond the direct cloud provider left it exposed to a risk that ISO/IEC 27036's multi-tier framework is designed to manage.

→ Correct. This is the principle most CCSP exam questions in this domain are testing. ISO/IEC 27036 explicitly recognises that risk does not stop at the direct provider. A breach originating at a third-tier vendor (firmware manufacturer serving the cloud provider's hardware supplier) is precisely the supply chain risk that a mature programme must account for, even though the organisation has no direct contract with that vendor.

C. Cloud providers should be held solely responsible for all security events originating in their supply chains, regardless of the organisation's due diligence.

→ Incorrect. While cloud providers bear responsibility for managing their own supply chains, the organisation retains accountability for its security governance. CCSP exam questions do not expect candidates to conclude that all responsibility lies with the provider; they test whether the candidate understands the shared responsibility model in a supply chain context.

D. Hardware firmware vulnerabilities are an acceptable residual risk in cloud environments because they cannot be assessed by cloud customers.

→ Incorrect. The existence of a risk that is difficult to assess does not make it acceptable by default. Organisations must evaluate whether the residual risk is within their appetite and implement mitigating controls (such as requiring cloud providers to demonstrate hardware supply chain assurance practices) even when direct assessment is not feasible.